UNIVERSITY OF LONDON

BSc EXAMINATION 2022

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3612: CYBER SECURITY

IY3612R: CYBER SECURITY – PAPER FOR FIRST SITS/RESIT CANDIDATES

Time Allowed: **TWO** hours

Attempt **three** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.
© Royal Holloway University of London 2022

Question 1 Control Systems Security

(a) Control systems designers must trade off parameters determining the response behaviour to disturbances.

(i) Explain how a design which minimises the amplitude of any *ringing* will respond to an attack in which an adversary is able to repeatedly inject commands, moving a controlled variable away from its current set point. In answering, assume that the control system is able to obtain correct readings of all variables otherwise. [7]

(ii) In a simple feedback loop control system design, the latency between a physical measurement and its processing by a control system will need to be considered in high-speed, real-time applications.

How will an attacker with the ability to delay a small fraction (e.g. 10%) of messages from a sensor to the control system? Explain the possible effects on the behaviour of the control system. [6]

(b) The ISO/IEC 61850 protocol in conjunction with the ISO/IEC 64283 standard offers advanced security features for automation and control systems. For use cases that do not require fast and hard real time operation, the MMS sub-protocol can be protected by a TLS channel according to the security standard ISO/IEC 64283.

Assume that an adversary is able to *inject* messages on a network where connections are protected as specified above. Would this adversary be able to cause harm, and if so which? Give a brief, reasoned explanation. [6]

(c) Consider an industrial system (e.g. a steam cracker in a refinery) in which the regular control system and the safety instrumentation system (SIS) are separated, but are provided with measurements from the same sensors.

Under which circumstances would an adversary be able to force the system into a harmful state? Give a brief, reasoned explanation. [6]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2 Attacks Against SCADA Systems

(a) The electrical transmission grid must be balanced at all times to ensure that voltage and frequency are within acceptable ranges throughout the network. To this end, the transmission system operator (TSO, National Grid in the case of the UK) must obtain real-time measurements from a large geographical area and control generation and demand accordingly.

The grid is a sparse network with sensors placed at vertices and edges of this network.

(i) Assume an adversary is able to identify a part of the grid which forms a sub-graph that is connected to the rest of the grid in only one location, and that the adversary is able to *delay* but otherwise not modify readings of a small number of phase angle and frequency taken by phasor measurement units (PMUs) in this sub-graph.

Which effects (if any) can this attack have on the state of the grid seen by the *state estimation algorithm* used by the TSO? Give a reasoned answer. [9]

(ii) Can the attack outlined in question 2(a)(i) be constructed successfully if it is **not** possible to inject messages into the communication path between the PMU (sensor) and state estimator? Give a reasoned answer. [7]

(b) Consider a SCADA system in which components from multiple vendors are used. An attacker has successfully breached one component in an OT network exploiting a vulnerability and has been able to take control of an Intelligent Electronic Device (IED) by way of a supply chain attack, but wishes to inject code into a PLC on the same network.

Under what circumstances and how can this succeed if the adversary has no way of communicating with the compromised IED? Briefly describe both assumptions and attack mechanism. [9]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3 Internet Robustness

(a) Correct operation of the Border Gateway Protocol (BGP) is required for worldwide connectivity across the Internet and any other service relying on this connectivity.

(i) Consider an advanced persistent threat (APT) able to infiltrate major network equipment vendors (e.g. Cisco, Juniper) software supply chain in a way that causes core routers used for BGP traffic to re-start at random intervals, but no more frequently than once per day.

What impact on connectivity would such a scenario have? Give a qualitative assessment and identify the effects observable globally. [9]

(ii) An adversary succeeds in manipulating the *internal* routing of an Autonomous System (AS) so that selected traffic is no longer forwarded from one BGP edge router of the AS to another.

How will this affect the *external* behaviour of the AS, and would this behaviour be recognisable as the result of an attack? Give a brief, reasoned answer. [9]

(b) The administrators of two AS have agreed to periodically take snapshots of their routing tables for comparison. They are employing a machine learning approach to identify anomalies and have spotted a recent change in behaviour where routes to *some* prefixes appear to be different even though the routes share a common AS ancestor for other prefixes.

Formulate a hypothesis for what may cause these divergent routes that may explain the observed behaviour and explain whether or how it may be possible to verify or refute the hypothesis. [7]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4 Network Robustness and Resilience Models

(a) The Inoperability Input-Output model is characterised by the equation

$$\mathbf{q} = \mathbf{A}^*\mathbf{q} + \mathbf{c}^*$$

where $\mathbf{c}^*$ is a vector characterising the final demand as a fraction of normal demand, $\mathbf{A}^*$ is the interdependency matrix indicating the degree of coupling each service or sector has expressed as rows in the matrix, and $\mathbf{q}$ a vector giving normalised loss of function (e.g. ratio of unrealised service or production minus degraded service).

If an analyst has sufficient data for modelling two service-oriented architectures, and now wishes to study the *combination* of these two systems and their vulnerability to constituent service inoperability, how would this be formulated? [9]

(b) Graph models can also be employed to capture both dependencies and flows. Consider a network of gas pipelines connecting a country R with other countries A, B, and C where three vertex-independent paths reach A, two vertex-independent paths reach B, but only one reaches C.

(i) Qualitatively extend the graph model outlined above to also include the *capacity* of the pipeline network reaching each of A, B, and C. How can this model be used to minimise the flow reaching C without a similar reduction in flows to A and B?

An algorithm sketch is sufficient for this answer. [9]

(ii) Consider a substantially larger, expanded network that is k-connected ($k \geq 2$). If an attacker is able to bring at most $k-1$ arbitrary nodes under its control, is it still possible to establish a flow from the source node R to an arbitrary destination node v? Give a reasoned answer. [7]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5 Adversary Modelling

(a) The MITRE ATT&CK frameworks (e.g. for Enterprise or Industrial Control Systems) contain matrices which represent an adversary's tactical objectives. These tactics can then be used to categorise adversary techniques.

(i) Is the framework sufficient to allow *inference* of adversary techniques based on observations of previous techniques? Give a reasoned answer. [8]

(ii) The original MITRE ATT&CK matrix was supplemented in 2020 by the MITRE ATT&CK for Industrial Control Systems (ICS) framework. Give a reasoned explanation why the ICS environment would require a different framework rather than an adaptation of the existing framework. [9]

(b) Can an Attack-Defence Tree (ADT) be used to represent an attack where a malicious command can only be effective if it is given in a particular system state, but where this system state cannot be observed but must be estimated? Give a brief reasoned answer, this may also use a equational or graph representation. [8]

END

Stephen Wolthusen

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.